



SECURE THE RANGE

END-TO-END CYBERSECURITY ASSESSMENT

Client: Nimbus Retail Co.
Cyber Security Analyst Internship Program

Prepared By: Zaid Qazi
Institute: IT-SIMPLERA Institute
Supervisor: Talal Rehan
Submission Date: 24 August 2026

PROJECT SCOPE & OBJECTIVES



Content:

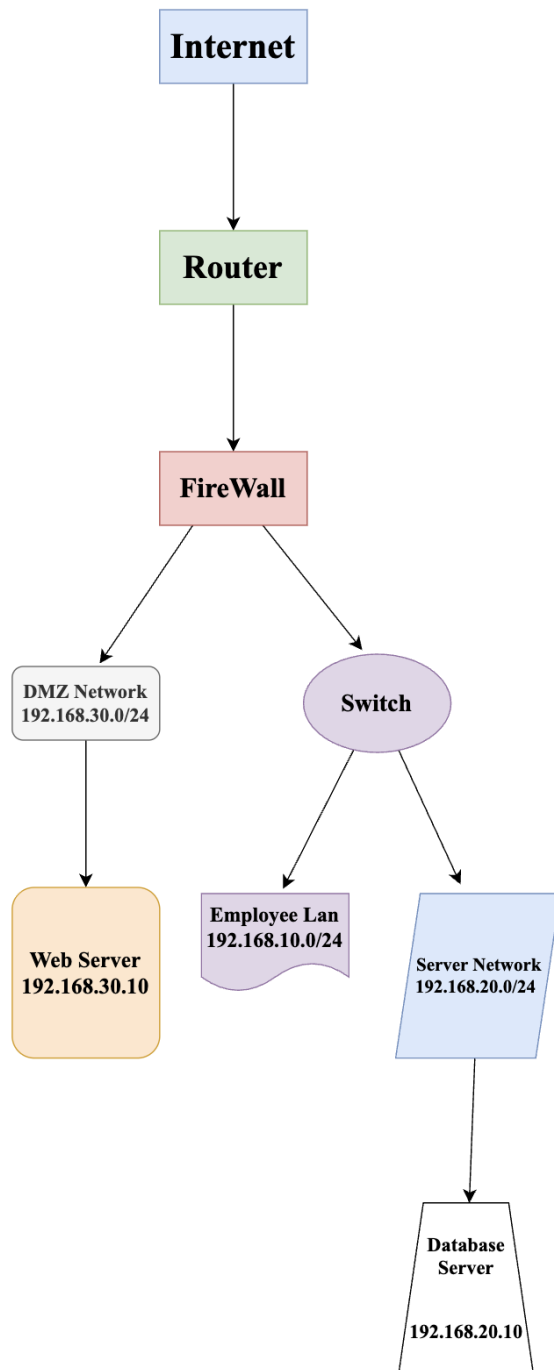
Scope

- Security assessment of a simulated e-commerce environment
- Passive OSINT and reconnaissance
- Network and service enumeration
- Web technology identification
- Vulnerability and risk assessment
- TLS and security configuration review

Objectives

- Identify exposed services and potential security weaknesses
- Map discovered vulnerabilities to CVEs and CVSS scores
- Evaluate overall security risk
- Recommend appropriate remediation measures
- Develop an incident response approach
- At the bottom, add a small line:

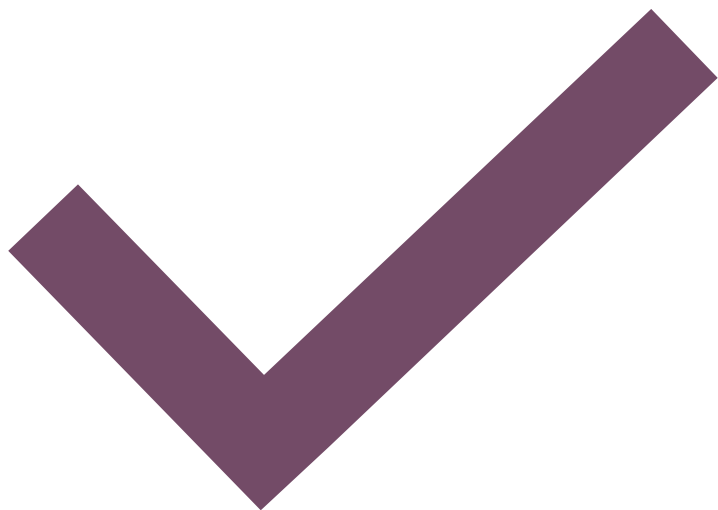
Assessment Environment: Authorized lab environment using TryHackMe for passive OSINT and Metasploitable 2 (192.168.64.8) for active security assessment.



SECURE NETWORK ARCHITECTURE

- **Key Security Features**
 - Firewall between the Internet and internal network
 - Separate **Employee LAN**: 192.168.10.0/24
 - Separate **Server Network**: 192.168.20.0/24
 - **DMZ**: 192.168.30.0/24
 - Web Server isolated in the DMZ
 - Database Server protected inside the server network
 - Network segmentation reduces unauthorized access
-

RECONNAISSANCE & OSINT



Tools Used

- WHOIS
- Certificate Transparency Logs
- Google Dorking
- Subfinder
- Social Media OSINT

Key Findings

- Target domain: tryhackme.com
- Registrar identified as **NameCheap, Inc.**
- Cloudflare name servers identified
- Multiple public subdomains discovered
- Examples: auth.tryhackme.com, vpn.vm.tryhackme.com, status.tryhackme.com
- Public login page identified through Google dorking
- More than **10 subdomains** identified using Subfinder

NETWORK SCANNING & ENUMERATION

```
(zaid@kali)-[~]
$ nmap -sV 192.168.64.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 18:19 +0500
Nmap scan report for 192.168.64.8 (192.168.64.8)
Host is up (0.00060s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Subuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 22:EA:02:5F:25:F9 (Unknown)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs:
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.05 seconds
```

Target: Metasploitable 2 (192.168.64.8)

Nmap Scans Performed

- nmap → Basic port scan
- nmap -sV → Service/version detection
- nmap -O → Operating system detection
- nmap -A → Aggressive/detailed scan
- nmap -p- → All TCP ports

Key Findings

- Target OS: **Linux 2.6.X**
- Multiple open ports and exposed services detected
- FTP: **vsftpd 2.3.4**
- SSH: **OpenSSH 4.7p1**
- HTTP: **Apache 2.2.8**
- MySQL: **5.0.51a**
- PostgreSQL: **8.3.x**
- Additional services included SMB, VNC and Tomcat

Main Result:

nmap -A provided the most detailed information.

WEB APPLICATION SECURITY REVIEW

```
(zaid@kali)-[~]  
$ whatweb http://192.168.64.8  
http://192.168.64.8 [200 OK] Apache[2.2.8], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][  
Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.64.8], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable  
2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]  
  
(zaid@kali)-[~]  
$
```

Technology Stack Identified

- **Operating System:** Ubuntu Linux
- **Web Server:** Apache 2.2.8
- **Programming Language:** PHP 5.2.4
- **WebDAV:** Enabled
- Web applications included **DVWA**, **Mutillidae**, **phpMyAdmin** and **TWiki**

Relevant OWASP Risks

- Broken Access Control
- Injection
- Security Misconfiguration
- Identification & Authentication Failures
- Vulnerable and Outdated Components
- Cryptographic Failures

Key Observation:

The website was accessible through **HTTP**, while **HTTPS** was not available, leaving web traffic unencrypted.

TOP VULNERABILITY FINDINGS

Key Finding:

- CVE-2011-2523 was the highest-priority vulnerability identified. The affected vsftpd 2.3.4 distribution contains a malicious backdoor that can provide unauthorized remote shell access.

Recommended Priority:

Critical vulnerability → remediate immediately

High vulnerability → high priority

Medium vulnerability → remediate after higher-risk findings

Vulnerability	Affected Service	CVSS	Severity
CVE-2011-2523	vsftpd 2.3.4	9.8	 Critical
CVE-2007-2447	Samba 3.0.20	6.0	 Medium
CVE-2007-4825	PHP 5.2.4	7.5	 High

RISK ASSESSMENT & TLS REVIEW

TLS Findings

- **Port 80 (HTTP): Open**
- **Port 443 (HTTPS): Closed**
- Web traffic was **not protected by HTTPS/TLS**
- Unencrypted traffic can expose sensitive information
- HTTPS with a valid TLS certificate should be implemented

Key Finding:

- The environment contains high-risk vulnerabilities and lacks encrypted web communication.

Vulnerability	Likelihood	Impact	Risk
CVE-2011-2523	High	High	Critical
CVE-2007-2447	Medium	High	High
CVE-2007-4825	High	Medium	High

REMEDIATION RECOMMENDATIONS

Remove or upgrade vsftpd 2.3.4 and use a secure file-transfer solution where required.

Upgrade Samba and PHP to supported and patched versions.

Enable HTTPS/TLS and redirect HTTP traffic to HTTPS.

Disable unnecessary ports and services to reduce the attack surface.

Apply firewall rules and network segmentation between public and sensitive systems. Follow the

Principle of Least Privilege for users and services. Perform **regular patching, vulnerability scanning, logging, and monitoring**.

CONCLUSION & OVERALL SECURITY POSTURE

- A complete security assessment was performed using an **authorized lab environment**. OSINT revealed multiple publicly visible assets and subdomains. Nmap identified several exposed and outdated network services. Three significant vulnerabilities were analyzed using **CVE and CVSS**. The highest identified severity was **Critical (CVSS 9.8)**. Web traffic was available over HTTP without HTTPS/TLS protection. Immediate patching, service hardening, HTTPS/TLS, network segmentation, and continuous monitoring are recommended.

Overall Assessment

Overall Security Posture: **HIGH RISK**

- The identified weaknesses should be addressed before deploying a production e-commerce environment.

Thank You

